

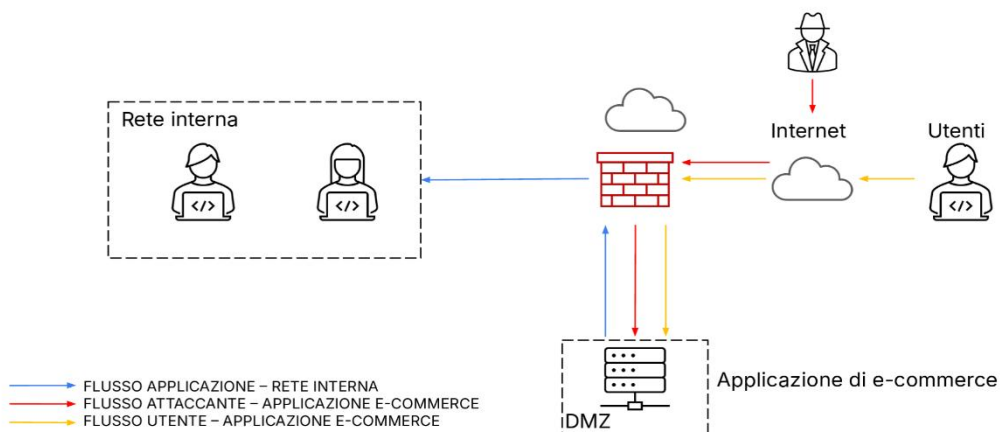
RELAZIONE TECNICA INFRASTRUTTURA E-COMMERCE HIGH DESIGN LEVEL (HDL)

La presente Relazione definisce le linee guida per la completa ristrutturazione e messa in sicurezza della rete aziendale e piattaforma di e-commerce a essa collegata. L'obiettivo è la transizione da un modello infrastrutturale parzialmente esposto e vulnerabile verso un'architettura moderna sicura e orientata ai principi fondamentali del **Defensive-in-Depth** e dello **Zero-Trust**.

Architettura di rete:

L'applicazione di e-commerce deve essere disponibile per gli utenti tramite Internet per effettuare acquisti sulla piattaforma.

La rete interna è raggiungibile dalla DMZ per via delle policy sul firewall, quindi se il server in DMZ viene compromesso potenzialmente un attaccante potrebbe raggiungere la rete interna.



Quesiti e Requisiti del progetto:

Quesito 1. Azioni preventive: quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo **SQLi** oppure **XSS** da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni

Quesito 2. Impatti sul business: l'applicazione Web subisce un attacco di tipo **DDoS** dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica

Quesito 3. Response: l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

Quesito 4. Soluzione completa: unire i disegni dell'azione preventiva e della response (unire soluzione 1 e 3

1) Analisi Delle Criticità dell'infrastruttura d'esame:

La riprogettazione dell'infrastruttura si è resa necessaria a seguito del rilevamento di gravi vulnerabilità che hanno impattato direttamente sull'operatività e il fatturato aziendale.

- 1) **Assenza di filtri applicativi perimetrali:** La mancanza di sistemi di ispezione dedicati espone direttamente l'applicazione web di e-commerce a vettori di attacco con possibile esfiltrazione di dati o manomissioni del codice tramite attacchi di tipo **SQL Injection** e **XSS**
- 2) **Eccessiva permeabilità della rete interna:** Il server web in **DMZ** dispone di policy di routing che permettono l'avvio di sessioni e connessioni verso la rete interna Aziendale che dovrebbe invece essere protetta. Questa configurazione espone l'intera Azienda al rischio di **Lateral Movement**.
- 3) **Saturazione delle risorse e vulnerabilità ai DDoS:** L'assenza di meccanismi di controllo dei flussi di dati permette attacchi di tipo **Distributed Denial of Service (DDoS)** di saturare la banda Aziendale, causando casi di inaccessibilità totale alla piattaforma con gravi danni economici e di immagine.

2) Obiettivi di sicurezza

La strategia di ristrutturazione infrastrutturale è stata resa necessaria per soddisfare i tre pilastri della sicurezza informatica (CIA Triad) bilanciando la protezione con la continuità del business.

2.1) Riservatezza (Confidentiality):

La riservatezza dei dati è l'obiettivo principale per tutelare i dati sensibili a disposizione dalle aziende. L'infrastruttura deve garantire che i dati sensibili di ogni utente, credenziali di accessi e informazioni varie siano e rimangano inaccessibili ai soggetti non autorizzati. Una delle misure principale per garantire la riservatezza è l'utilizzo di cifratura e algoritmi complessi come **l'AES-256** che rendano quasi impossibile la decifratura dei dati sensibili.

2.2) Integrità (Integrity):

L'integrità si basa sull'accuratezza e l'impossibilità che il dato venga modificato o si modifichi nel tempo. L'architettura di un sistema informatico deve dunque garantire e preservare l'integrità dei dati della rete interna isolando i sistemi in modo che un eventuale malware sul server web non possa alterare, infettare o cifrare le postazioni di lavoro dei dipendenti e i dati sensibili degli utenti.

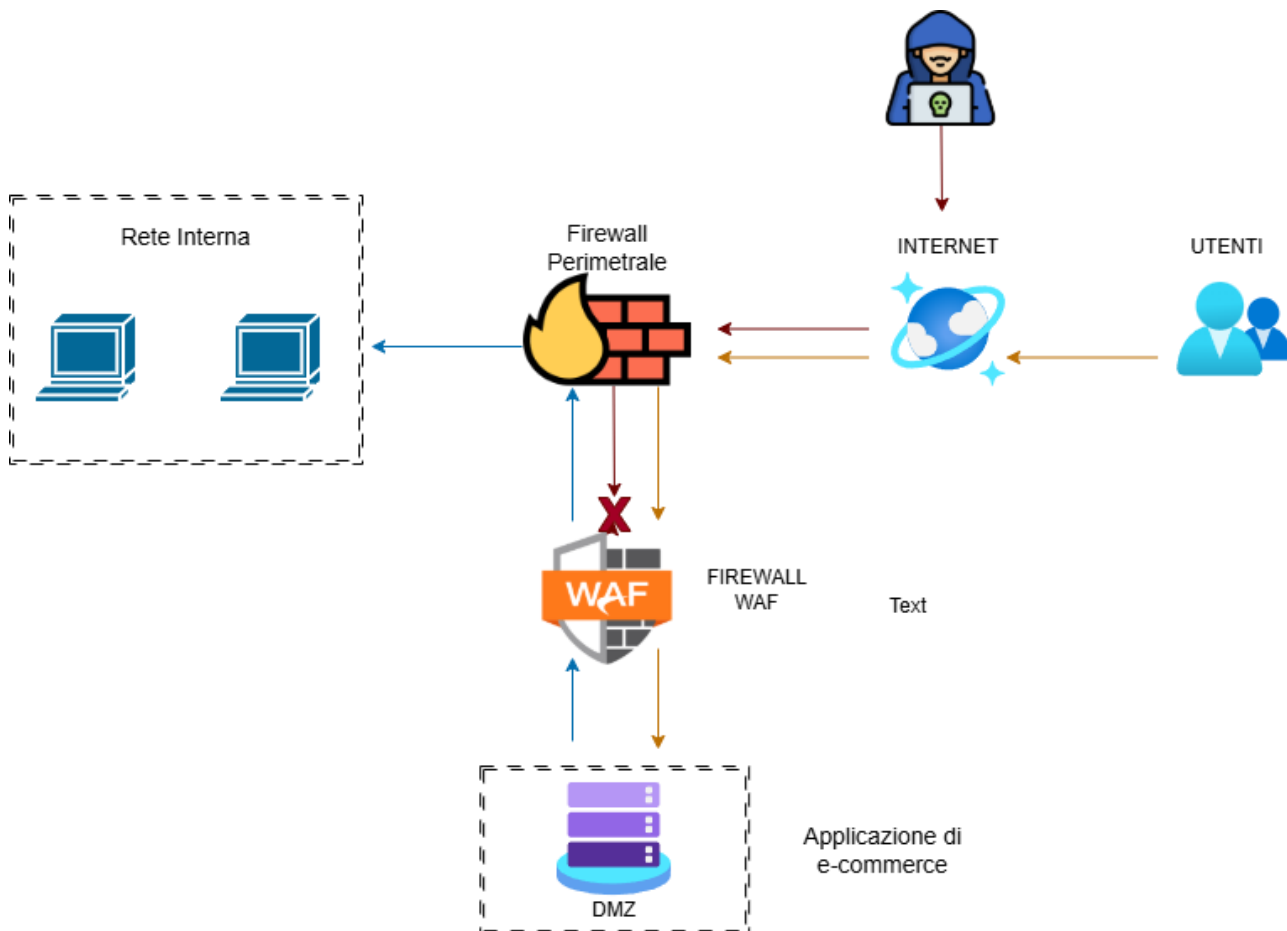
2.3) Disponibilità (Availability)

La disponibilità è la capacità del sistema di riuscire in maniera continua a fornire il determinato servizio messo a disposizione e i suoi dati. Questo vale anche in casi critici come attacchi o disastri naturali; quindi, l'azienda deve sempre mettere a disposizione i suoi servizi e renderli sempre disponibili.

3) Quesito 1: Azioni Preventive contro SQLi & XSS

Per difendere l'applicazione e-commerce dai vettori di attacco come SQL Injection e Cross-site Scripting (XSS) si è deciso di implementare questa soluzione:

Dato che gli attacchi di SQLi e XSS sfruttano la mancata validazione degli input dell'utente nei moduli web, se un attaccante invia caratteri speciali o codice SQL/Javascript malevolo e l'applicazione li esegue in maniera diretta, può esfiltrare dati nel database, rubare i cookie di sessione di utenti come visto durante il corso. Per questo si è deciso e reso necessario l'implementazione di un filtro perimetrale che blocchi il payload malevolo prima ancora che raggiunga il server web e causi un incidente.



AZIONI:

Infrastrutturale: Viene introdotta un dispositivo hardware dedicato che si inserisce tra il firewall perimetrale e il Server web dell'e-commerce in **DMZ**, il **WAF** (Web Application Firewall). Il **WAF** lavora al livello 7 (Applicativo), quando un'utente invia una richiesta, quest'ultima viene intercettata dal WAF ed eseguita la decifratura del traffico **HTTPS** (SSL/TLS) per ispezionare il payload in chiaro confrontandole con un set di regole ovvero le Core Rule Set **OWASP**. Qualsiasi richiesta contenente stringhe **SQL** malevole o **script** non autorizzati viene scartata e mostra un **errore HTTP 403 (Forbidden)**.

Applicativa (Secure Coding): Come visto nelle Lezioni precedenti è Obbligatorio implementare "quarry parametrizzate" ovvero una tecnica per costringere il database a trattare l'input dell'utente come dati e mai come codice, questo per neutralizzare strutturalmente la

SQLi, unita ovviamente alla sanitificazione rigorosa degli INPUT e all'escaping dei caratteri speciali in output per bloccare gli XSS.

4) Quesito 2: Impatti sul business

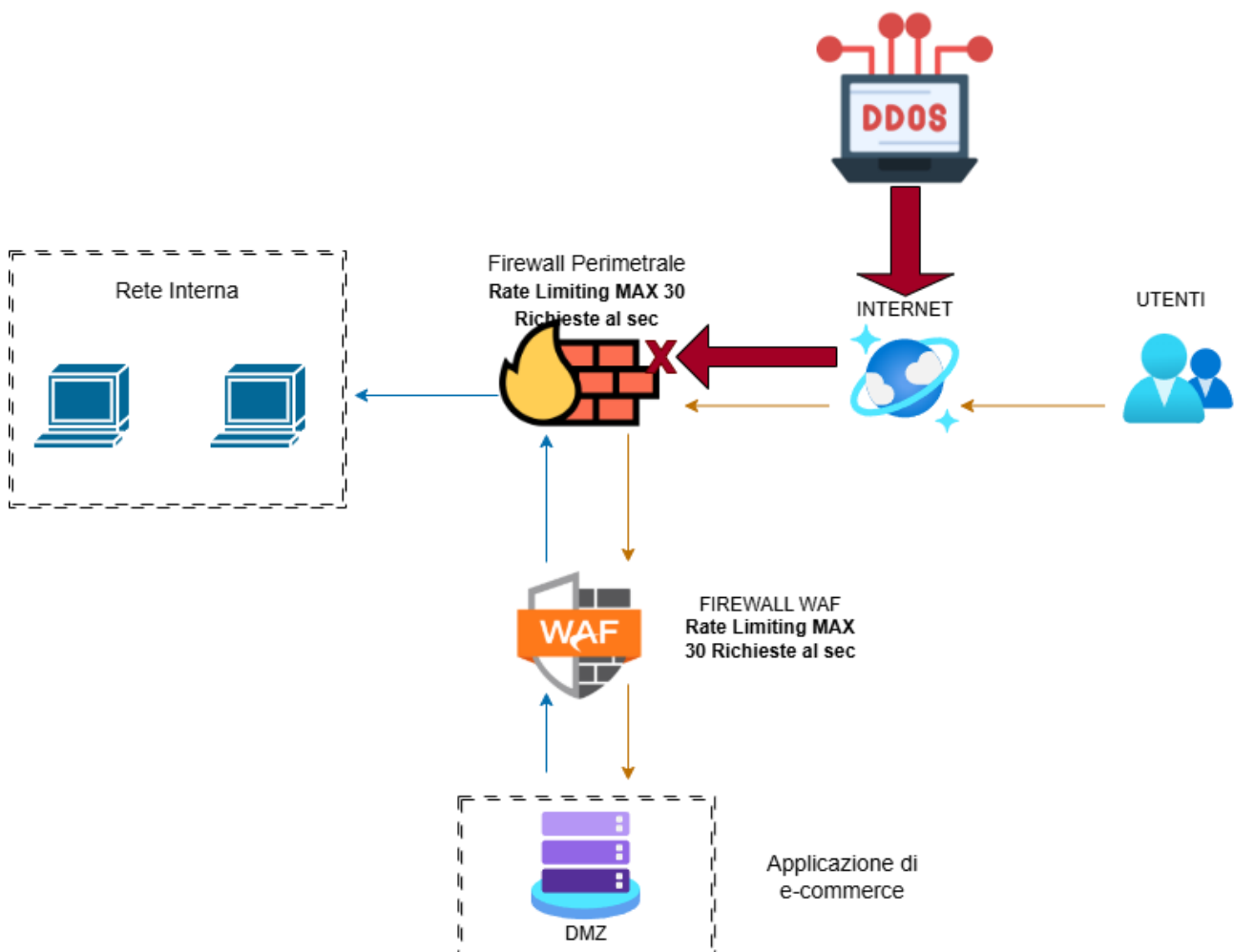
L'applicazione Web subisce un attacco di tipo **DDoS** dall'esterno che rende l'applicazione non raggiungibile per 10 minuti.

Impatto sul business considerando che in media ogni minuto gli utenti spendono 1500 €

L'impatto finanziario diretto calcolato sulla base dello storico è pari a:

Danno = 10 min x 1.500€/min = 15.000€

Un attacco DDoS (Distributed Denial of Service) non mira a rubare dati, ma a rendere il servizio inaccessibile e non disponibile saturando la banda di rete oppure la CPU del server tramite milioni di richieste simultanee. Per un e-commerce, ogni minuto di inattività significa soldi persi e fatturato distrutto oltre al danno di immagine per l'azienda. Per questo motivo si è deciso di optare alla seguente soluzione:



AZIONI: Non disponendo di Budget infinito per servizi Cloud esterni, il **Firewall perimetrale** e il **WAF** locale vengono configurati con regole di **Rate Limiting applicativo**. Il sistema, in questo modo, monitora il numero di connessioni contemporanee per singolo **indirizzi IP** o **subnet** e ne accetta solamente max 30 al sec. Se una macchina esterna supera questa soglia

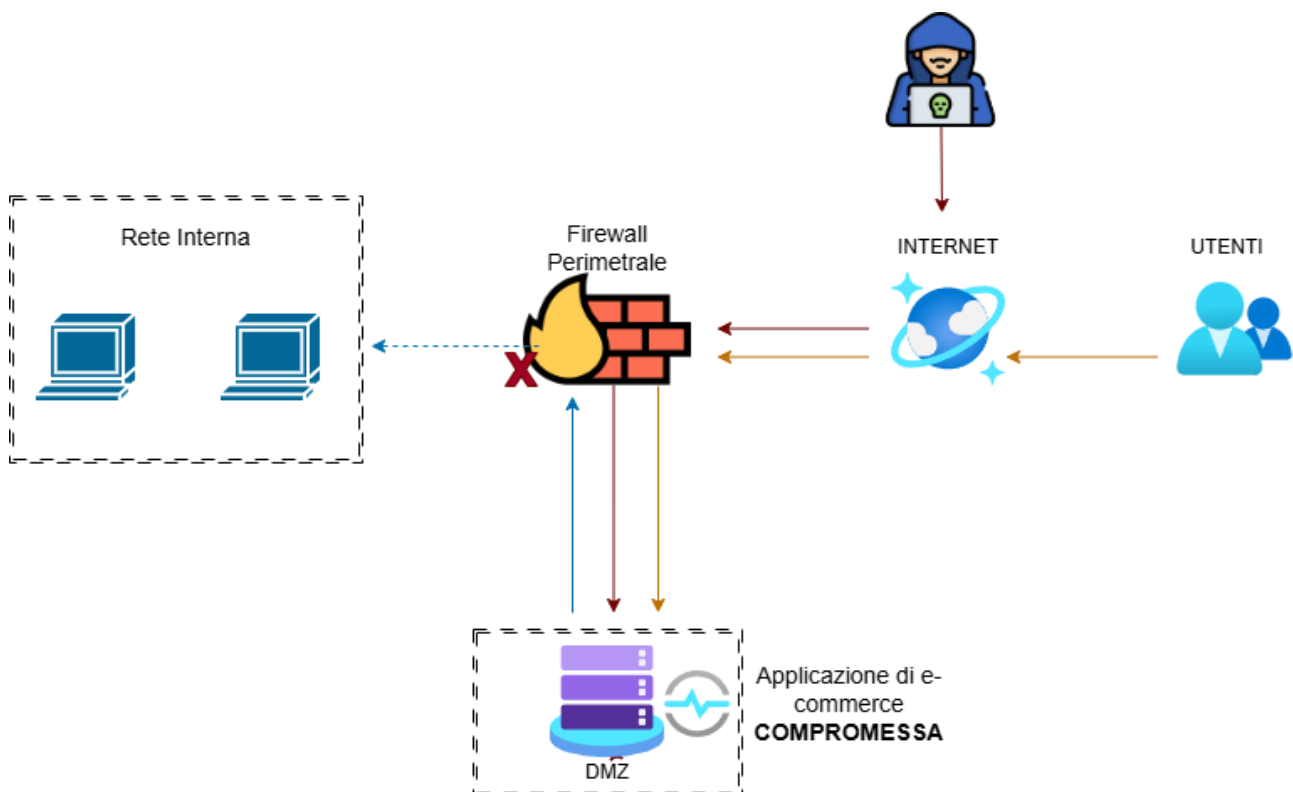
i **Firewall** applicano una regola di **Drop** o **Null Routing**, scartando i pacchetti e impedendo di saturare banda o la CPU del server. Configurando la regola su entrambi i firewall si evita **DDoS volumetrico** nel caso del Firewall perimetrale e **DDoS Applicativo** come http Flood nel WAF.

5) Quesito 3: Response (Contenimento Malware)

l'applicazione Web viene infettata da un **malware**. La vostra priorità è che il **malware** non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata.

Quando un server web in DMZ viene infettato da un malware, il pericolo più grande è il Lateral Movement (Movimento Laterale). Soprattutto se la DMZ ha accesso alla rete interna il pericolo è ancora più grande dato che il malware cercherà di infettare i PC dei dipendenti, i server aziendali ecc. La priorità assoluta è isolare la minaccia contenendola all'interno della DMZ, sacrificando temporaneamente la macchina web anche per studiare la minaccia e l'attaccante a nostro vantaggio.

Per la risoluzione di questo incidente si è decisa la seguente soluzione per garantire la sicurezza della rete interna e il contenimento del pericolo:



AZIONI:

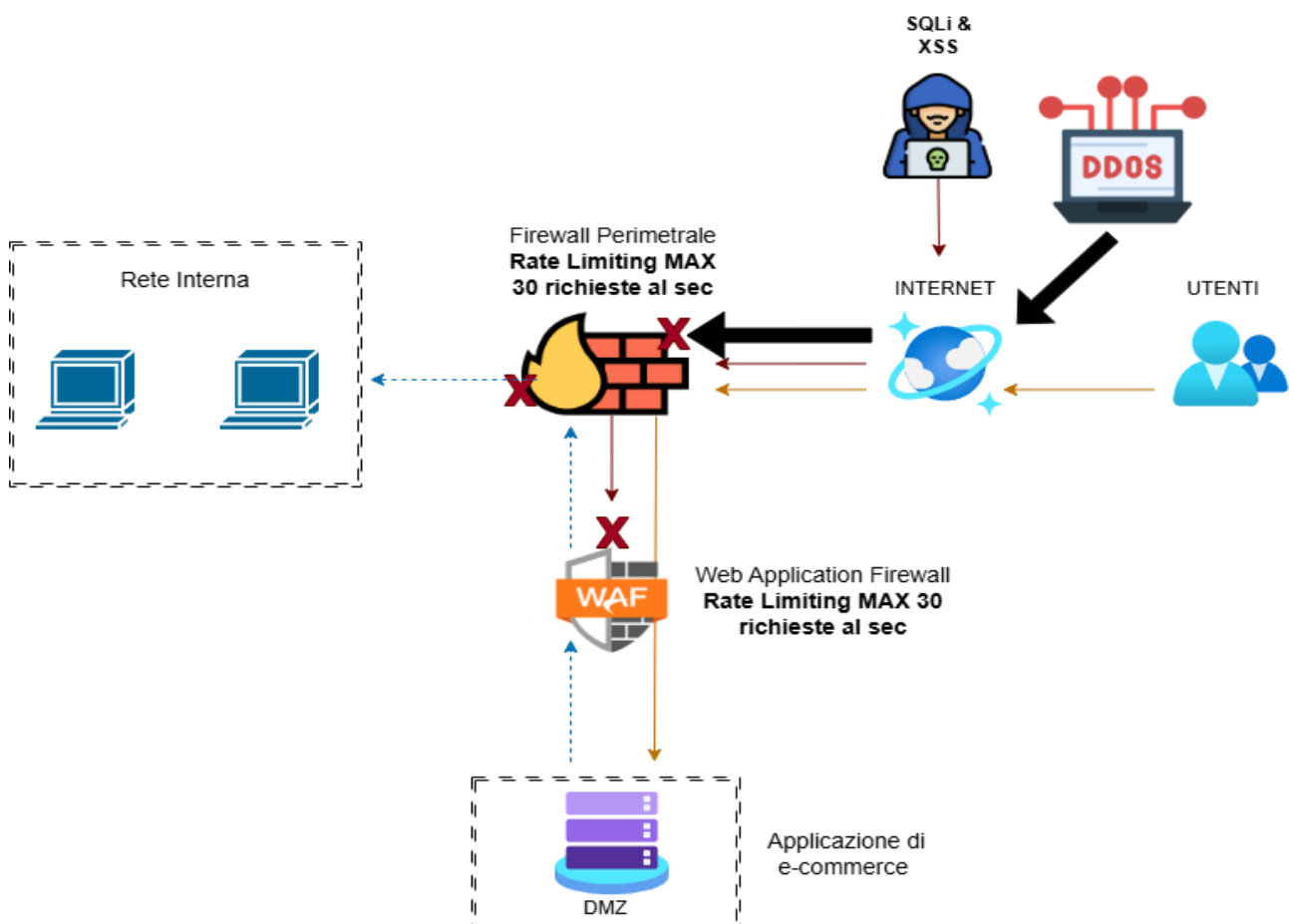
- **Isolamento Logico:** Agendo sulle **ACL** (Access Control List) del **Firewall Perimetrale** disattiviamo la regola permissiva che permetteva il collegamento della **DMZ** alla rete Interna, in questo modo qualsiasi pacchetto generato dal server web compromesso che tenterà di dirigersi verso la sottorete interna viene intercettato dal Firewall e Droppato immediatamente senza alcuna risposta all'attaccante.

- **Vantaggio:** Dato che la rete aziendale è protetta dal server web compromesso e l'attaccante ancora connesso al **server web**, ci permette tramite un eventuale team di sicurezza di monitorare le connessioni verso i server del malware e raccogliere **log**, fare **analisi forense** come se fossimo in un ambiente controllato (**Sandbox**)

6)Quesito 4: Soluzione Completa

Per la risoluzione delle problematiche di sicurezza analizzate si è proposta la seguente soluzione per la risoluzione completa dei pericoli:

Un'infrastruttura di sicurezza deve essere "RESILIENTE" sia in fase di prevenzione che in fase di gestione degli incidenti. Unendo le due soluzioni otteniamo un'infrastruttura con una postura difensiva stratificata (Defense in Depth) durante un'eventuale crisi in atto.



Funzionamento: Il sistema opera combinando i controlli di livello 7(WAF) e i controlli di routing del firewall:

- Il traffico in ingresso da internet continua a essere ripulito dal **WAF**, riducendo le possibilità che un attaccante possa sfruttare ulteriori vulnerabilità applicative. Contemporaneamente, se l'infezione di malware è già radicata sul server, il firewall centrale mantiene la regola di **DROP** attiva per il traffico della DMZ, impedendo di contaminare la rete interna. Inoltre ogni **firewall** è configurato con regole di **Rate**

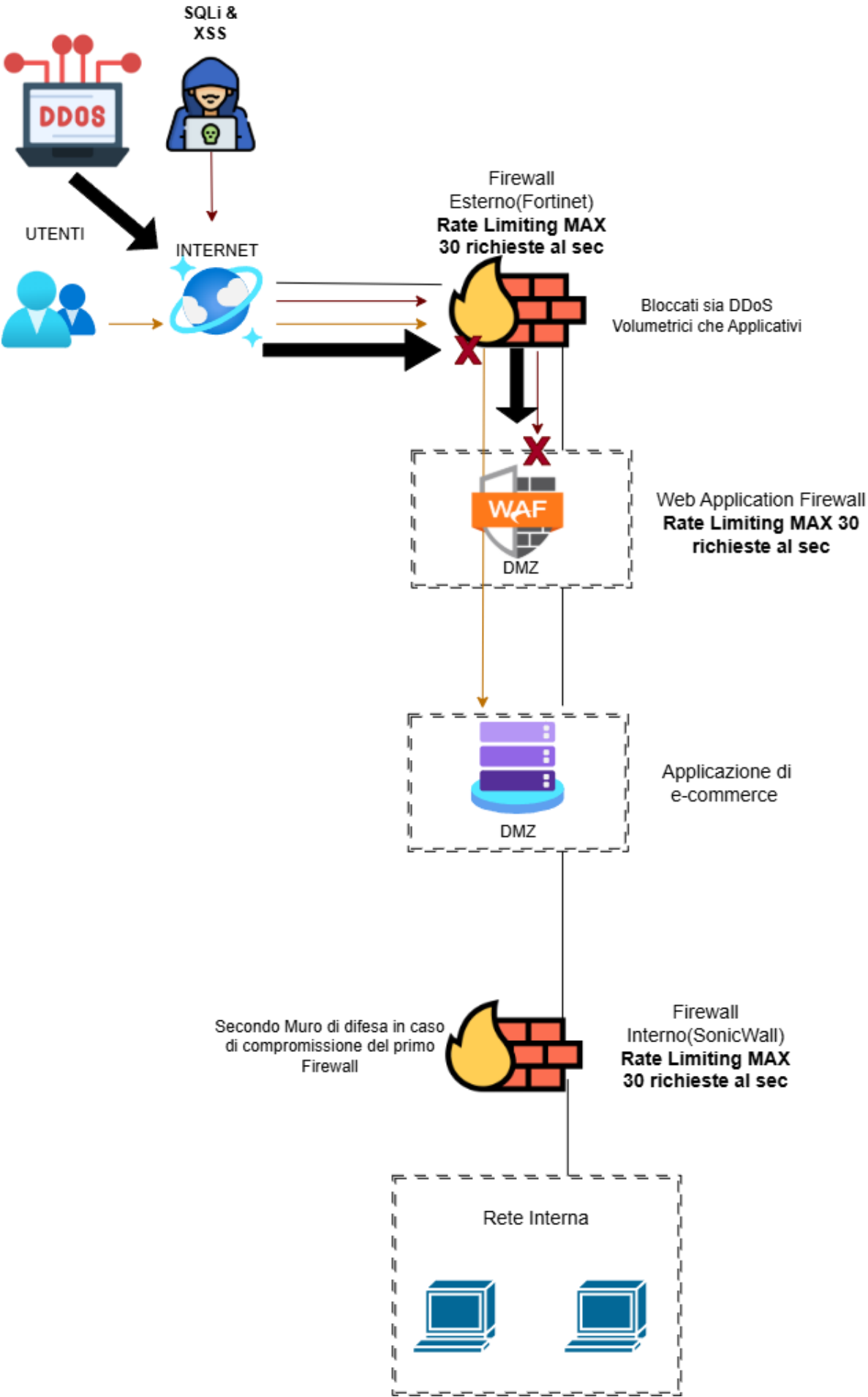
Limiting applicativo per evitare attacchi di tipo **DDoS** di tipo volumetrico nel **firewall perimetrale** e di tipo **applicativo (http Flood)** nel **Web Application Firewall**.

6) Quesito 5: Infrastruttura Budget da 35.000€

Nonostante le modifiche e migliorie apportate all'infrastruttura originale, è presente comunque un grave difetto, ovvero viene utilizzato un unico firewall perimetrale per suddividere tutto, se quel singolo firewall dovesse venir compromesso tramite vulnerabilità (Zero Day) l'intera azienda cadrebbe. Inoltre, tenere il server web nella stessa DMZ espone i dati sensibili dei clienti in caso di violazioni.

È quindi stato elaborata un'infrastruttura di tipo militare con vari strati difensivi per ovviare i problemi precedentemente descritti:

Componente Scelto	Modello / Specifica Tecnica	Costo (IVA escl.)	Voce di Bilancio	Impatto Cyber e Giustificazione del Rischio
Firewall Hardware Esterno	Appliance NGFW (es. Fortinet FortiGate 60F o sim.)	€ 4.500,00	CAPEX (Hardware)	Primo sbarramento perimetrale. Gestisce il Rate Limiting contro i DDoS volumetrici della rete.
Firewall Hardware Interno	Appliance NGFW (es. SonicWall TZ470 o sim.)	€ 4.500,00	CAPEX (Hardware)	Secondo sbarramento di sicurezza. Essendo un produttore diverso rispetto al primo, azzerava il rischio di vulnerabilità Zero-Day.
Server Hardware WAF/Proxy	Server Rack Dedicato (es. Dell PowerEdge / HPE)	€ 4.000,00	CAPEX (Hardware)	Appliance computazionale locale dedicata al motore ModSecurity + HAProxy per la decifratura e il blocco di SQLi/XSS.
Licenze CyberSecurity	Pacchetto Security Suite & Signature IPS/AV (12 Mesi)	€ 4.000,00	OPEX (Software)	Abbonamento agli aggiornamenti continui delle firme dei malware per entrambi i firewall fisici.
Infrastruttura di Backup	Storage NAS Locale Cifrato + Spazio Cloud Immutabile	€ 3.500,00	CAPEX + OPEX	Soluzione anti-ransomware con politica di conservazione blindata dei dati dell'e-commerce.
Professional Services	Servizi professionali di Ingegneria di Rete, Setup e Hardening	€ 11.000,00	OPEX (Servizi)	Configurazione delle regole, separazione logica delle VLAN e collaudo dell'intera architettura eterogenea.
Fondo di Riserva Tecnica	Fondo di contingenza aziendale per imprevisti	€ 3.000,00	CAPEX/OPEX	Budget di sicurezza trattenuto per gestire eventuali sforamenti o hardware di micro-connezione.
TOTALE COMPLESSIVO	INVESTIMENTO TOTALE STRUTTURATO	€ 35.000,00		Pienamente conforme al budget massimo di progetto.



CAPEX: Spese per acquistare, aggiornare o mantenere asset fisici

OPEX: il denaro che si spende regolarmente per la gestione quotidiana delle attività e per far funzionare i sistemi nel breve termine

Di fronte al vincolo di 35.000 euro di budget, l'infrastruttura originale viene migliorata radicalmente creando un'architettura a doppia barriera (Multi-Vendor On-Premise)

- **Funzionamento della Doppia Barriera:** Al posto dell'utilizzo di un singolo apparato difensivo centrale, la rete viene migliorata implementando in serie due next-Generation Firewall di produttori differenti, un **Firewall Esterno Fortinet** e un **Firewall interno SonicWall**. L'implementazione di questa scelta elimina il rischio aziendale legato alle vulnerabilità **zero-day**: quindi un **exploit** in grado di compromettere il primo strato difensivo hardware risulterà totalmente inefficace contro il secondo essendo di un altro produttore, bloccando così l'attaccante a metà strada.
 - **Mitigazione DDoS:** Come evidenziato precedentemente, attacchi di tipo **DDoS Volumetrici** vengono intercettati ed eliminati sul **Firewall Esterno** grazie a policy di **Rate Limiting** (Max 30 richieste al sec) e per attacchi **DDoS di tipo Applicativi** come http Flood vengono invece bloccati dal **WAF** posto subito dopo il **firewall Esterno**. Parallelamente, le minacce di tipo **SQLi** e **XSS** vengono anche queste tramite il **WAF** analizzate e scartate permettendo il passaggio solo del traffico legittimo.
 - **Isolamento Zero-Trust della rete Interna:** L'applicazione di e-commerce e la rete interna dell'infrastruttura non condividono più alcun collegamento di comunicazione. Il **firewall Interno SonicWall** funge a secondo muro di difesa, qualsiasi tentativo di connessione o scansione provenienti dalla **DMZ** per via di compromissione ecc viene intercettato e scartato all'istante.
-

